

Spotit Wound Care

Information Asset Register and Record of Processing Activities

Organisation	Medholic Ltd
Product	Spotit Wound Care
Website	https://spotit-wound-app.medholic.net
Data protection contact	Lynda Chidi lynda.chidi@medholic.net 07984230265
Document status	Starter register for governance review Generated 29 Jul 2026

Purpose and Scope

This document combines a simple Information Asset Register (IAR) and Record of Processing Activities (ROPA) for Spotit Wound Care. It records the main types of information expected to be held, received, generated, shared, or protected by the Spotit platform.

This is a starter governance document for Medholic Ltd and should be reviewed, approved, and kept up to date before live use with real patient data. Adopting organisations may also need their own local DPIA, information governance review, and data processing agreement.

Roles

Role	Likely responsibility	Notes
Medholic Ltd	Supplier/platform provider and data processor where providing Spotit to customer organisations	Platform support, hosting, security, configuration, and agreed support access.
Customer organisation	Usually data controller for its own patients and staff	Determines lawful basis, local access, clinical use, retention, and patient-facing obligations.
Authorised staff users	Clinicians, coordinators, organisation admins, and platform admins	Access should follow role-based permissions and audit logging.

IAR/ROPA Register

The table below lists the main information assets and processing activities expected for Spotit. Lawful basis and retention should be confirmed with each adopting organisation before live clinical use.

Information asset / data category	Examples and purpose	Storage, access and protection	Sharing, retention and review
Patient demographic data	Name, title, gender, date of birth, NHS number or local identifier, address/postcode, contact details. Used to identify patients and link wound records to the correct person.	Held in the Spotit database within the relevant organisation workspace. Access limited to authorised staff. Protected by login, role permissions, encrypted transport, audit logs, and database controls.	Shared only with authorised care team members or exported where clinically required. Retention to follow the customer organisation's health record retention policy.
Wound assessment data	Wound type, site, measurements, wound bed, exudate, infection concerns, pain, review frequency, care plan, progress notes. Used for wound assessment and ongoing care planning.	Held against the patient record and organisation workspace. Access restricted by role. Changes should be audit logged with user, date, and action.	May be included in clinical reports or MDT sharing where approved. Retention to follow clinical record policy and contract terms.
Wound images	Wound photographs and image-based review evidence. Used for wound progress monitoring, assessment, reporting, and clinical review.	Stored securely with patient/wound record. Access restricted to authorised clinical users. Upload/download/export should be controlled and audited.	Shared only where clinically required and authorised. Retention follows clinical image/health record policy. Images should not be used for marketing unless anonymised and consented.
Clinician/staff accounts	Staff name, role, email, organisation, permissions, login activity, password status, optional MFA status. Used for authentication, access control, accountability, and support.	Held in Spotit user management tables. Access managed by organisation admins and platform admin controls. Passwords should be hashed; sessions should time out automatically.	Shared internally for administration and support only. Retention follows staff account/audit policy after leaving or account deactivation.
Audit logs	Who logged in, viewed, created, changed, exported, deleted, or administered records. Used for accountability, security monitoring, incident investigation, and governance evidence.	Stored centrally in the application database and linked to organisation, user, and action. Access should be limited to authorised admin/governance roles.	Shared during approved audits, incident reviews, or support investigations. Retention should meet healthcare audit and contract requirements.
Access request data	Name, role, email, organisation or buyer/investor request details, request date/time, request message. Used to manage demo access, buyer enquiries, and account approval.	Held in application/admin records. Access limited to Medholic Ltd platform/admin users responsible for access decisions.	Shared only for access management or follow-up. Retention should be limited to business need and deleted when no longer required.
Organisation subscription/admin data	Organisation name, admin contact, subscription status, billing mode, plan, workspace slug, staff count, usage statistics. Used to manage SaaS tenancy, subscriptions, billing, and customer support.	Held in platform administration records. Access limited to Medholic Ltd platform admin and authorised organisation admins for their own organisation.	May be shared with payment/accounting providers if payment processing is introduced. Retention follows business, contract, tax, and audit requirements.
Reports and PDF exports	Clinical summaries, wound progress reports, caseload reports, management/coordination outputs. Used for clinical communication, review, governance, and operational planning.	Generated within Spotit and may be downloaded/exported by authorised users. Export events should be audit logged.	Shared by the customer organisation according to local clinical governance. Retention depends on whether the report becomes part of the clinical record.
Support/contact messages	IT help requests, support concerns, contact forms, issue descriptions, screenshots where provided. Used for product support and problem resolution.	Held in support/admin systems or application support records. Staff should avoid including unnecessary patient identifiable information in support messages.	Shared with Medholic Ltd support team and approved technical suppliers if needed. Retention limited to support and audit need.
Email notifications	Access request notifications, account invitations, password reset communications, support notifications, administrative messages. Used to notify users and administrators.	Sent through approved email system/provider. Content should be minimised and avoid unnecessary patient-identifiable information.	Shared with intended recipients and email service provider. Retention depends on mailbox/provider settings and organisational policy.

Security Controls Summary

- Role-based access permissions should be applied so users only access the organisation and records they are authorised to use.
- Every patient record, wound record, report, and audit event should belong to a specific organisation workspace.
- Clinical access, changes, exports, deletions, and administration actions should be audit logged.
- Passwords should be protected by secure hashing, with strong password rules and automatic session timeout.
- Data should be encrypted in transit using HTTPS and protected at rest through database and hosting security controls.
- Backups, incident response, data deletion, and support access should be documented before live clinical use.

Review and Approval

Document owner	Lynda Chidi, Medholic Ltd
Review frequency	At least annually and whenever Spotit processing, suppliers, hosting, or clinical use changes.
Approval status	Draft - to be reviewed and approved before live patient data use.
Next action	Confirm lawful basis, retention schedule, supplier list, DPIA, and customer data processing agreement.